

Breach Notification

Policy Number	POL-HIM-081	Owner / Department	Compliance / Privacy Office
Effective Date	2023-04-01	Version	2.4
Last Revised	2026-03-12	Next Review	2028-03-12
Approved By	Compliance & Privacy Committee	Applies To	All workforce members and business associates; executed by the Privacy Office and Compliance

1. Purpose

This policy governs how Riverside Regional Medical Center responds to a breach of unsecured protected health information, consistent with the HIPAA Breach Notification Rule (45 CFR 164.400–414). It defines how a potential breach is assessed, who must be notified, and the deadlines for each notice.

2. Definitions

- **Breach** — the acquisition, access, use, or disclosure of unsecured PHI in a manner not permitted by the Privacy Rule that compromises the security or privacy of the PHI.
- **Discovery** — the first day the breach is known, or by reasonable diligence would have been known, to the facility. All notification clocks run from discovery.
- **Unsecured PHI** — PHI not rendered unusable, unreadable, or indecipherable through encryption or destruction per HHS guidance.

3. Four-Factor Risk Assessment

Unless an exception applies, an impermissible use or disclosure is presumed to be a breach unless the facility demonstrates a low probability that PHI was compromised, based on at least these four factors:

1. The nature and extent of the PHI involved, including identifiers and likelihood of re-identification.
2. The unauthorized person who used the PHI or to whom the disclosure was made.
3. Whether the PHI was actually acquired or viewed.
4. The extent to which the risk to the PHI has been mitigated.

4. Notification Recipients and Deadlines

Recipient	When required	Deadline
Affected individuals	Every breach of unsecured PHI	Without unreasonable delay; no later than 60 calendar days from discovery
HHS / OCR	Breach affecting 500+ individuals	Concurrently; no later than 60 days from discovery, via the OCR portal

Recipient	When required	Deadline
HHS / OCR (small breach log)	Breach affecting fewer than 500 individuals	Logged and submitted annually, within 60 days after year-end
Prominent media	Breach affecting 500+ residents of a State or jurisdiction	Without unreasonable delay; no later than 60 days from discovery

Individual notice is written and sent by first-class mail (or email if the individual agreed) and describes what happened, the PHI involved, steps individuals should take, what the facility is doing, and contact information.

IMPORTANT — The 60-day period is an outer limit, not a target. Begin individual notification as soon as the breach is confirmed. For any breach affecting 500 or more individuals, notify the Privacy Officer and Compliance immediately — this is a SEV-1 event — and submit the HHS/OCR and media notices concurrently with individual notice, no later than 60 days from discovery.

5. Severity & Reporting

Breaches are classified on the facility-wide scale in POL-RM-013. A breach of 500 or more individuals, or any large-scale PHI loss, is a SEV-1-level compliance event escalated to the Privacy Officer and Compliance immediately (within 1 hour). A confirmed breach under 500 individuals is typically SEV-2 (notify the Privacy Office within 4 hours). A suspected impermissible disclosure intercepted before PHI was acquired is a Near Miss (report within 24 hours).

6. References

- HIPAA Breach Notification Rule, 45 CFR 164.400–414 (individual notice 164.404, media notice 164.406, HHS notice 164.408).
- HHS guidance on securing PHI (encryption / destruction).
- Related: POL-HIM-080 (HIPAA Privacy), POL-RM-013 (severity & reporting).